CSE 331: Computer Security Fundamentals

Spring 2026

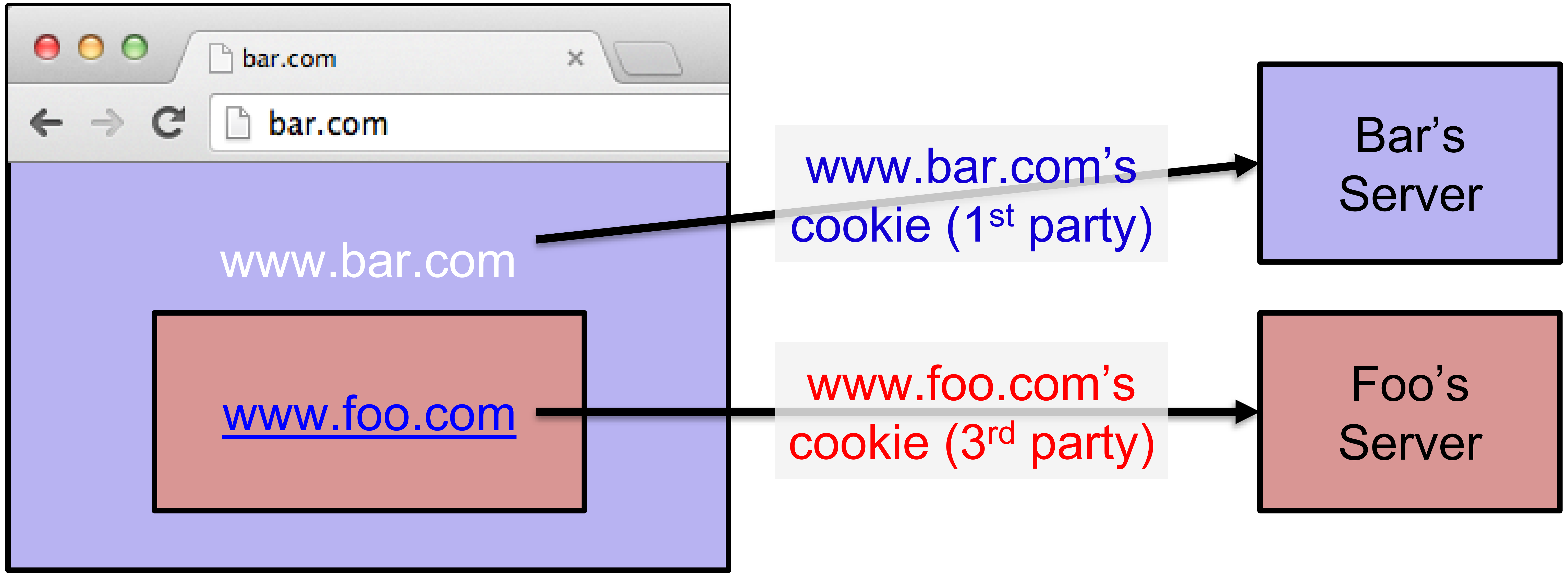
Web Security: Tracking & Privacy

Amir Rahmati
Xinrui Yu

Stony Brook Institute at Anhui University
安徽大学纽约石溪学院

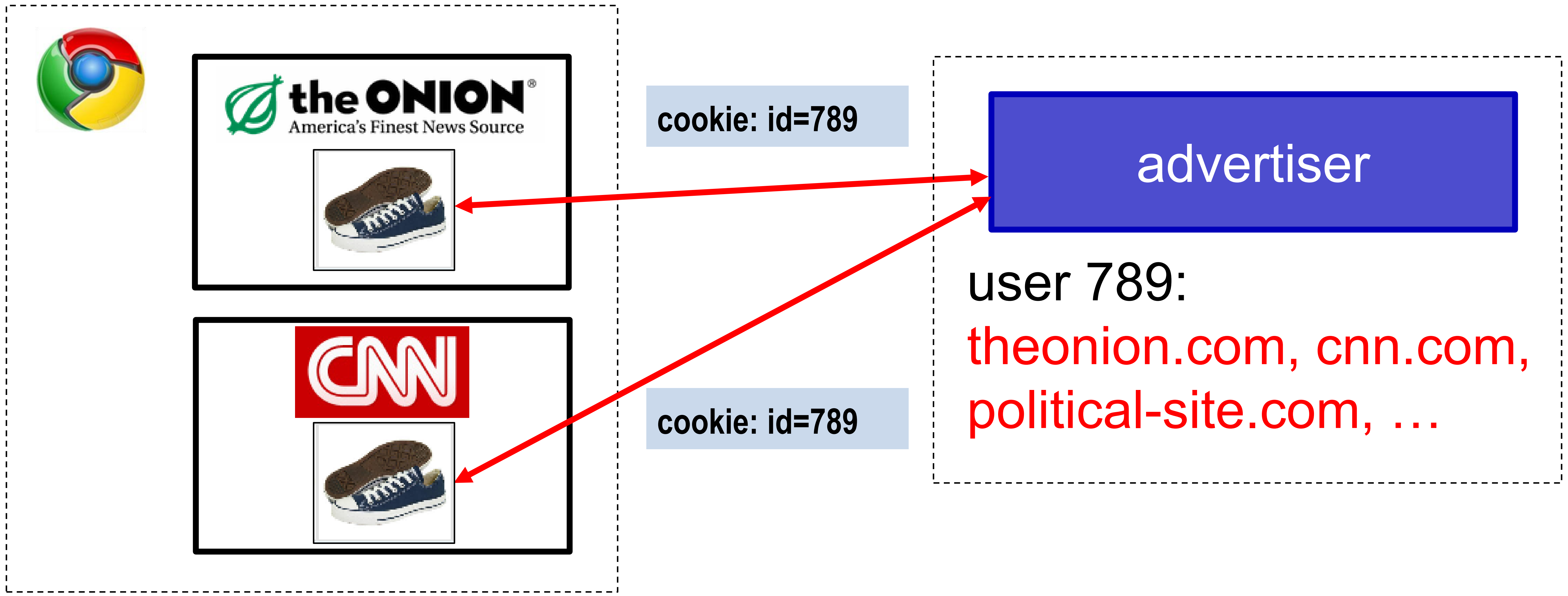
First and Third-Party Cookies

- First-party cookie: belongs to top-level domain.
- Third-party cookie: belongs to domain of embedded content (such as image, iframe).



Anonymous Tracking

Trackers included in other sites use third-party cookies containing unique identifiers to create browsing profiles.



Anonymous Tracking Example (1)

- **Action:** You visit a first-party site (e.g., CNN.com).
- **Mechanism:** Inside CNN's html code, there is an invisible <iframe> or a tiny 1x1 pixel image pointing to rubiconproject.com.

  They are called **web beacons** or **tracking pixels.**
- **Result:** Because your browser is sending a request to Rubicon, it can send a Set-Cookie header. This cookie contains a Unique ID (e.g., User_88x2-99j).
- You are now "tagged" in Rubicon's domain, even though you never visited their site directly.

Basic Tracking Mechanisms

- Tracking requires:
  (1)re-identifying a user.
  (2)communicating id + visited site back to tracker.

```
Hypertext Transfer Protocol
  GET /pixel/p-3aud4J6uA4Z6Y.gif?labels=InvisibleBox&busty=2710 HTTP/1.1\r\n
  Host: pixel.quantserve.com\r\n
  Connection: keep-alive\r\n
  Accept: image/webp,*/*;q=0.8\r\n
  User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_2) AppleWebKit/537.36
  Referer: http://www.theonion.com/\r\n
  Accept-Encoding: gzip,deflate,sdch\r\n
  Accept-Language: en-US,en;q=0.8\r\n
  Cookie: mc=52a65386-f1de1-00ade-0b26e; d=ENkBRgGHD4GYEA35MMIL74MKiyDs1A2MQI1Q
```

Anonymous Tracking Example (2)

- **Action:** You leave CNN and visit a completely different site, like Weather.com.
- **Mechanism:** Weather.com also uses Rubicon to sell ad space. When your browser loads the weather page, it again sends a request to Rubicon.
- **Result:** Your browser automatically sends the cookie back to Rubicon.
- Rubicon now knows that the same anonymous person who was just reading news is now checking the weather.

Anonymous Tracking Example (3)

- **Data Aggregation:** Over time, Rubicon sees User_88x2-99j on:
  - A tech blog (Interest: Computer Security)
  - An airline site (Interest: Travelling)
  - A fitness forum (Interest: Running)
  - ...and much more

- Rubicon don't know your name, but they have completed user profiling: they know your interest in every aspect, even your daily scheduling.

Anonymous Tracking Example (4)

- **Auction:** The next time you load a page, Rubicon holds a "Real-Time Bidding" (RTB) auction in milliseconds.
- They tell advertisers: “I have a user here who likes… and has the following habit: … Who wants to show them an ad?”
- You see a highly specific ad for a "Developer Conference in London."

Tracking Technologies

- HTTP Cookies
- HTTP Auth
- HTTP Etags
- Content cache
- IE userData
- HTML5 protocol and content handlers
- HTML5 storage

- Flash cookies
- Silverlight storage
- TLS session ID & resume
- Browsing history
- window.name
- HTTP STS
- DNS cache

- “Zombie” cookies that respawn (http://samy.pl/evercookie)

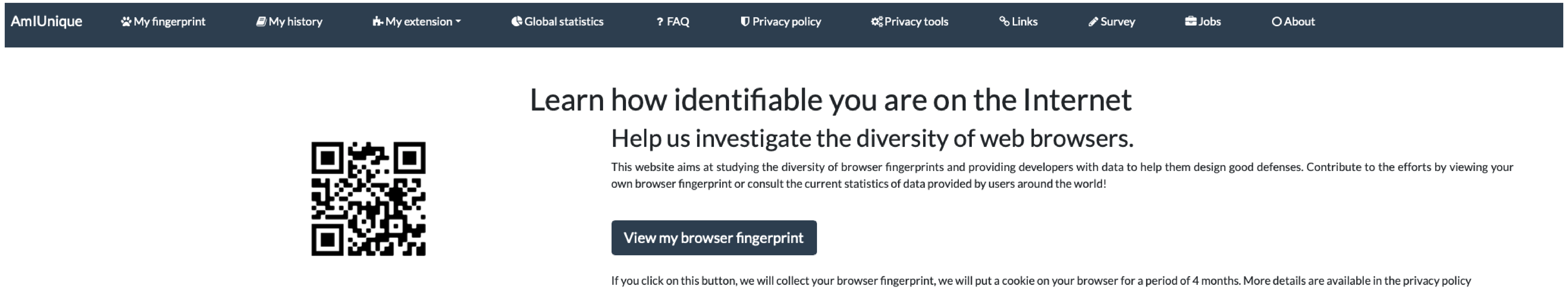
Fingerprinting Web Browsers

- User agent
- HTTP ACCEPT headers
- Browser plug-ins
- MIME support
- Clock skew
- Natural ordering of properties

- Installed fonts
- Cookies enabled?
- Browser add-ons
- Screen resolution
- HTML5 canvas (differences in graphics SW/HW!)
- Math constants from JS Engines

https://panopticlick.eff.org

Your browser fingerprint appears to be unique among the 229,038 tested in the past 45 days.



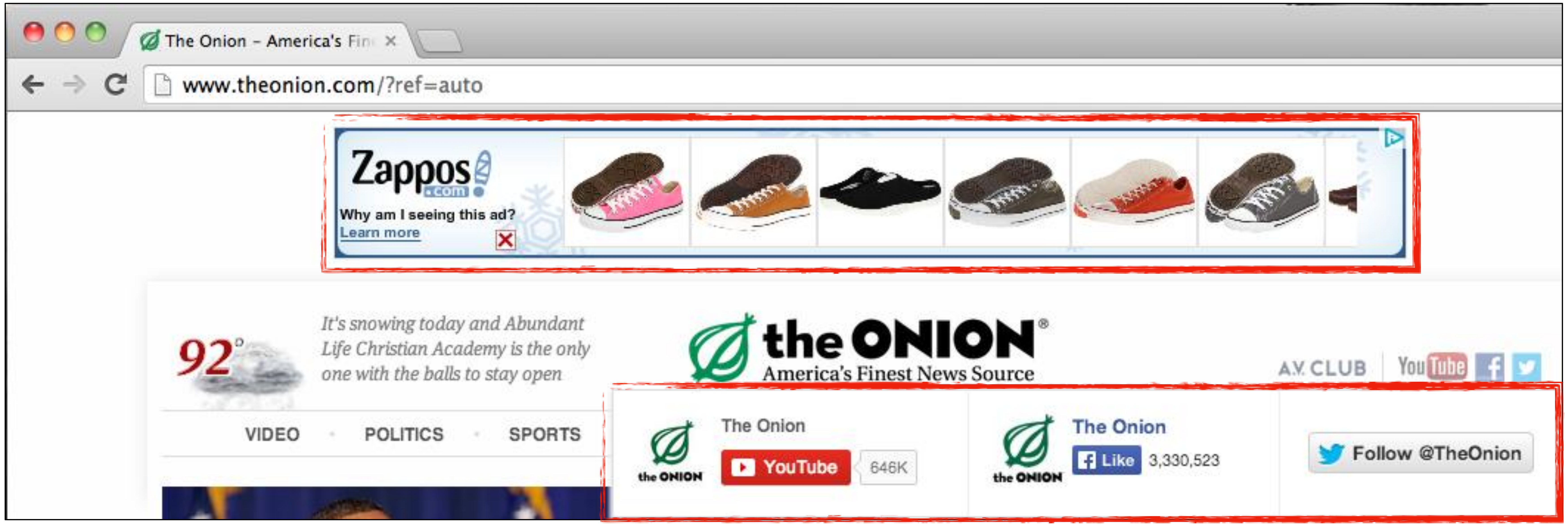
https://amiunique.org

You are unique among the 2,653,699 fingerprints in our entire dataset.

My Desktop Fingerprint

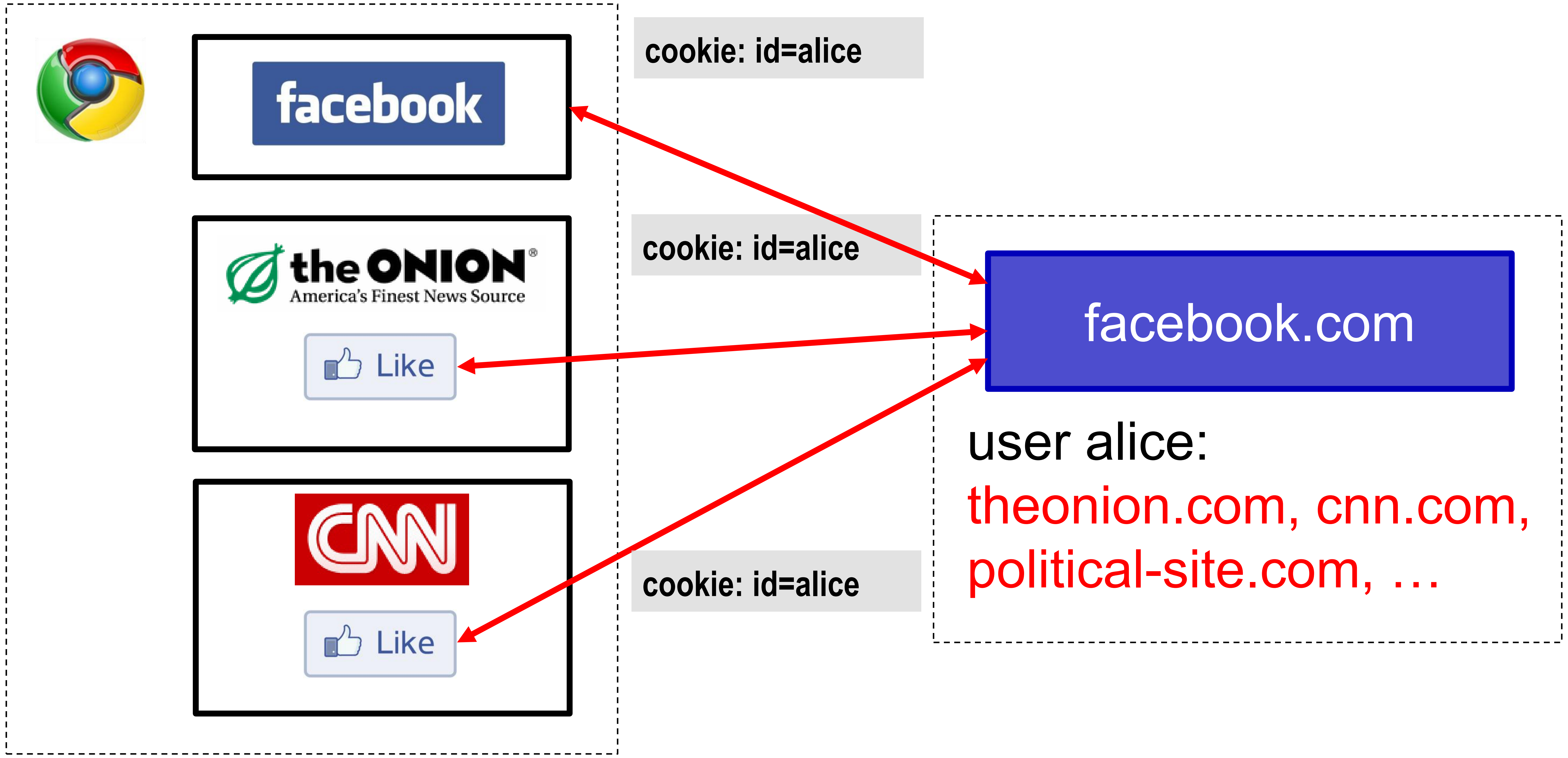
Proximity sensor	32.14%	false
Keyboard layout	21.58%	Not supported
Battery	18.93%	Not supported
Connection	16.92%	Not supported
key	37.71%	cookie
Location bar	36.47%	Visible
Menu bar	36.49%	Visible
Personal bar	36.46%	Visible
Status bar	36.47%	Visible
Tool bar	36.46%	Visible
Result state	29.01%	No value
List of fonts (Flash)	67.71%	Flash not detected
Screen resolution (Flash)	68.81%	Flash not detected
Language (Flash)	68.81%	Flash not detected
Platform (Flash)	68.81%	Flash not detected

Other Trackers?



"Personal" Trackers

Personal Tracking



- Tracking is not anonymous (linked to accounts).
- Users directly visit tracker's site → evades some defenses.

Measuring Web Tracking

Measurement Study

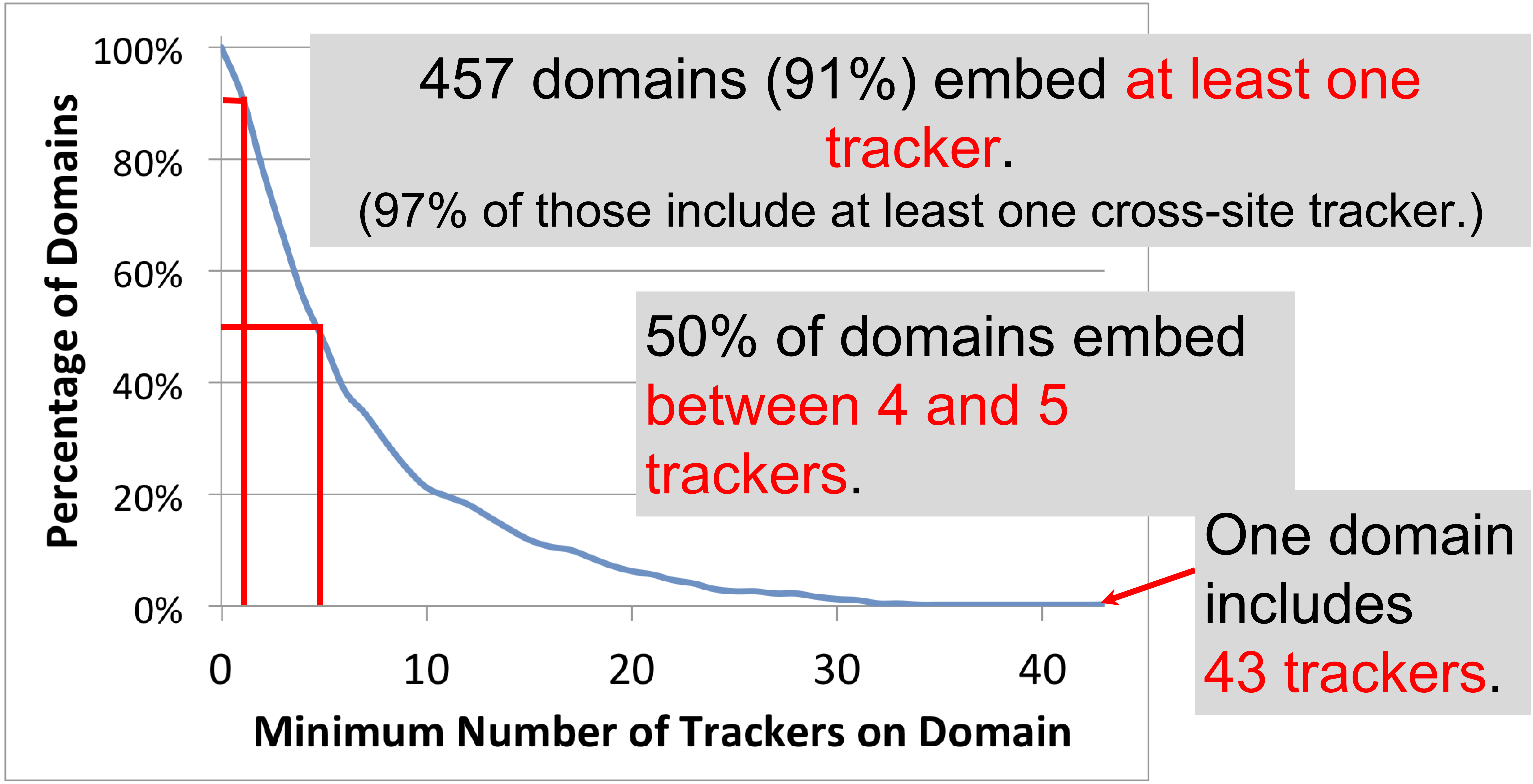
- **Questions:**
  - How prevalent is tracking (of different types)?
  - How much of a user's browsing history is captured?
  - How effective are defenses?

- **Approach:** Build tool to automatically crawl web, detect and categorize trackers based on our taxonomy.

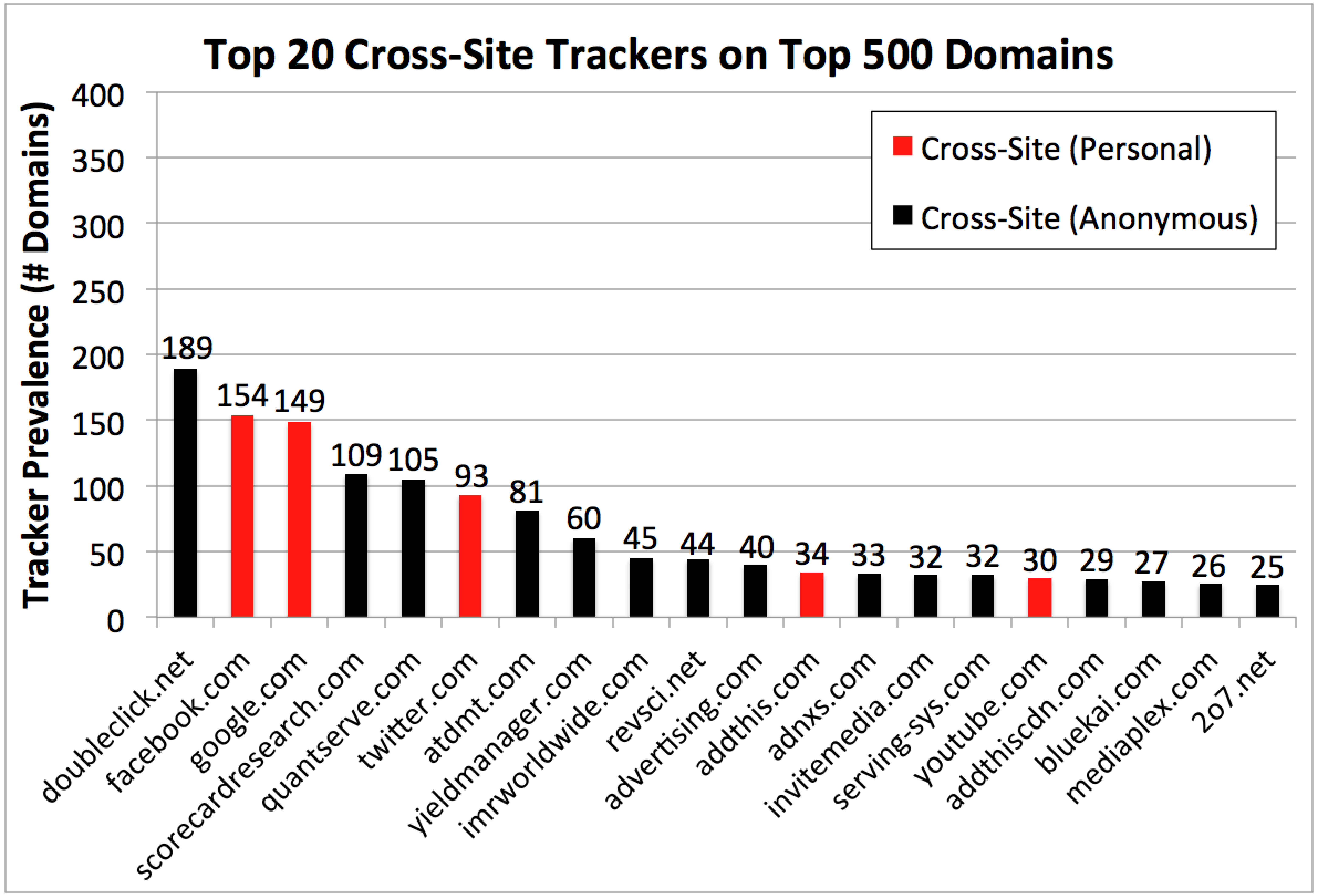
Longitudinal studies since then: tracking has increased and become more complex.

How prevalent is tracking? (2011)

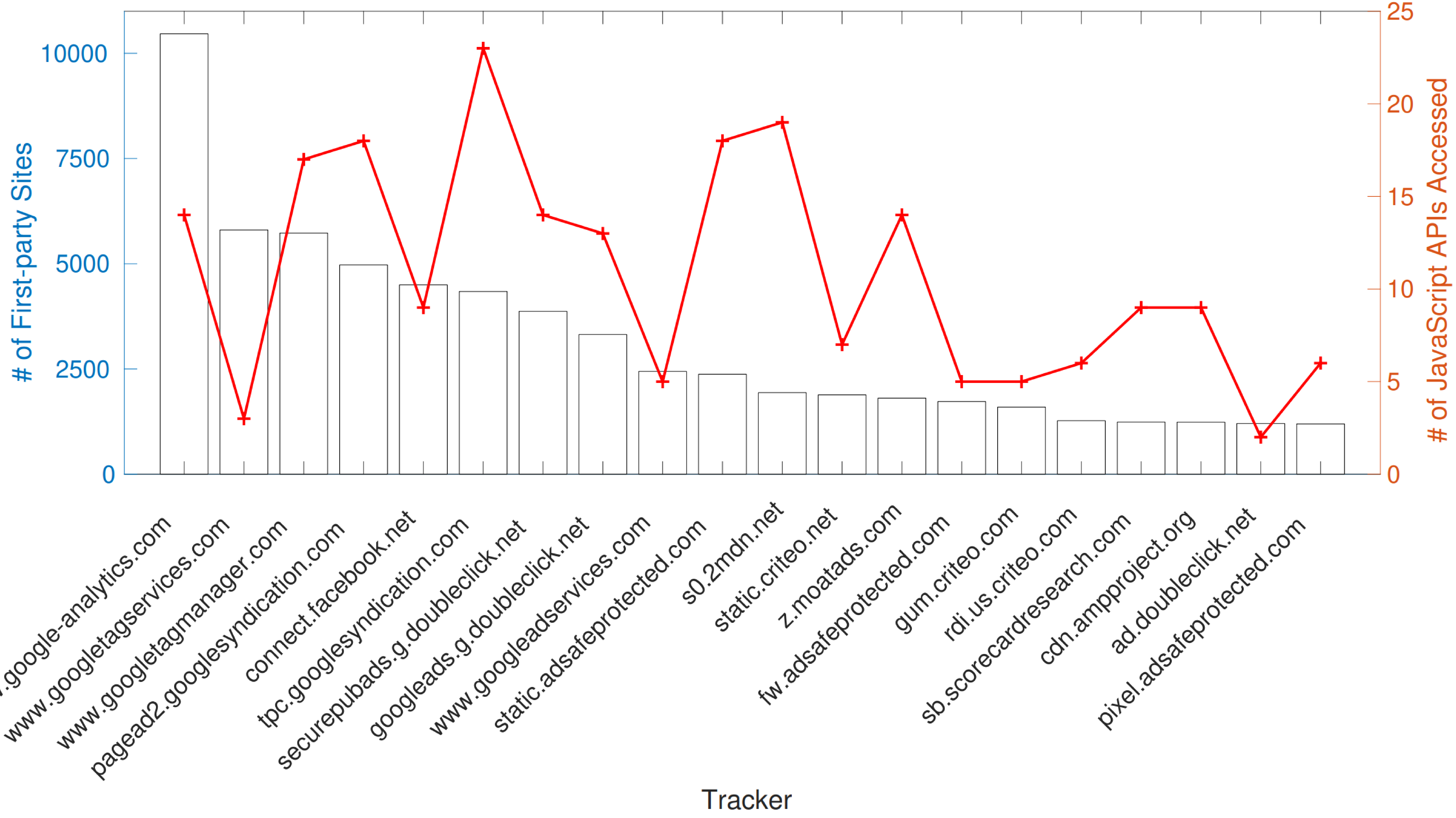
524 unique trackers on Alexa top 500 websites (homepages+ 4 links)



Who/what are the top trackers? (2011)



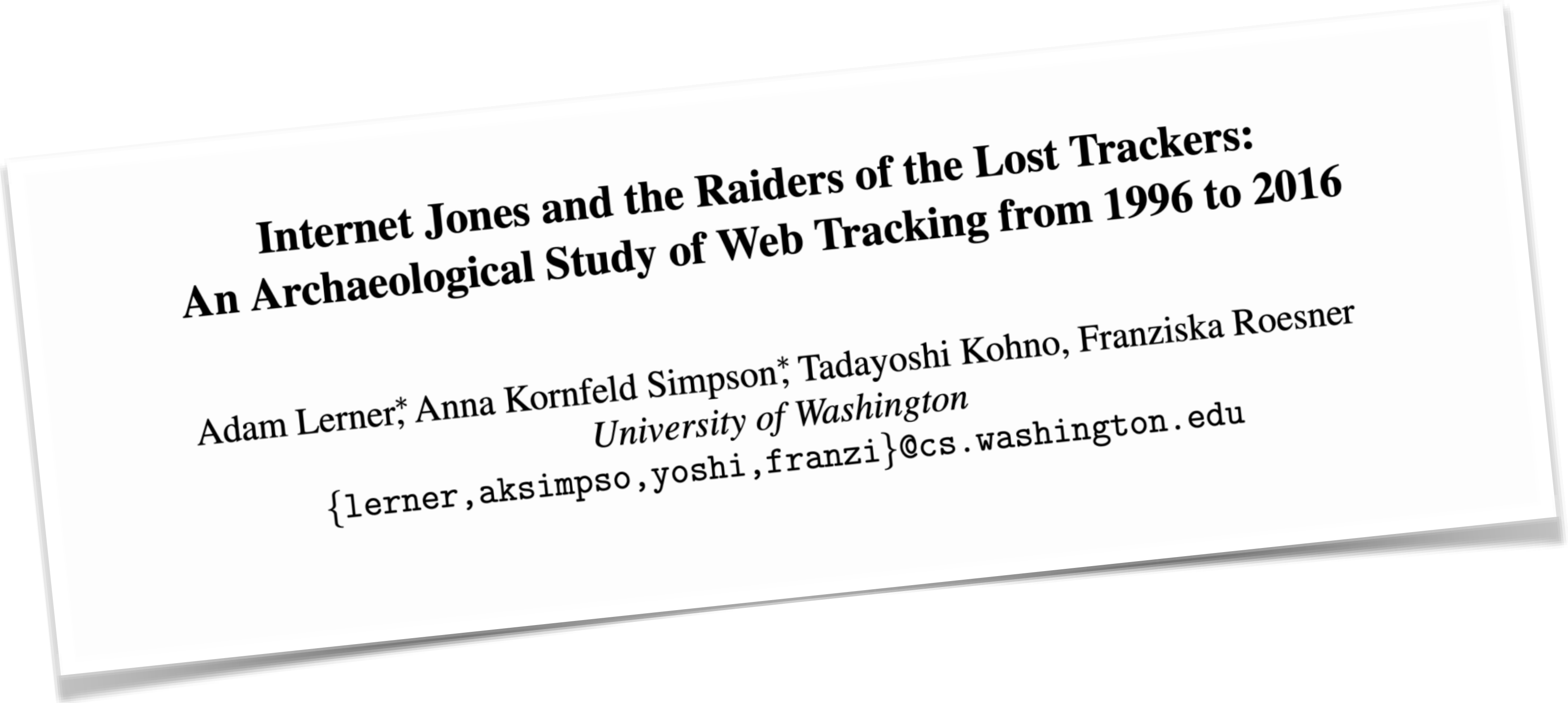
Who/what are the top trackers? (2020)



How has this changed over time?

- The web has existed for a while now…
  - What about tracking before 2011?
  - What about tracking before 2009?

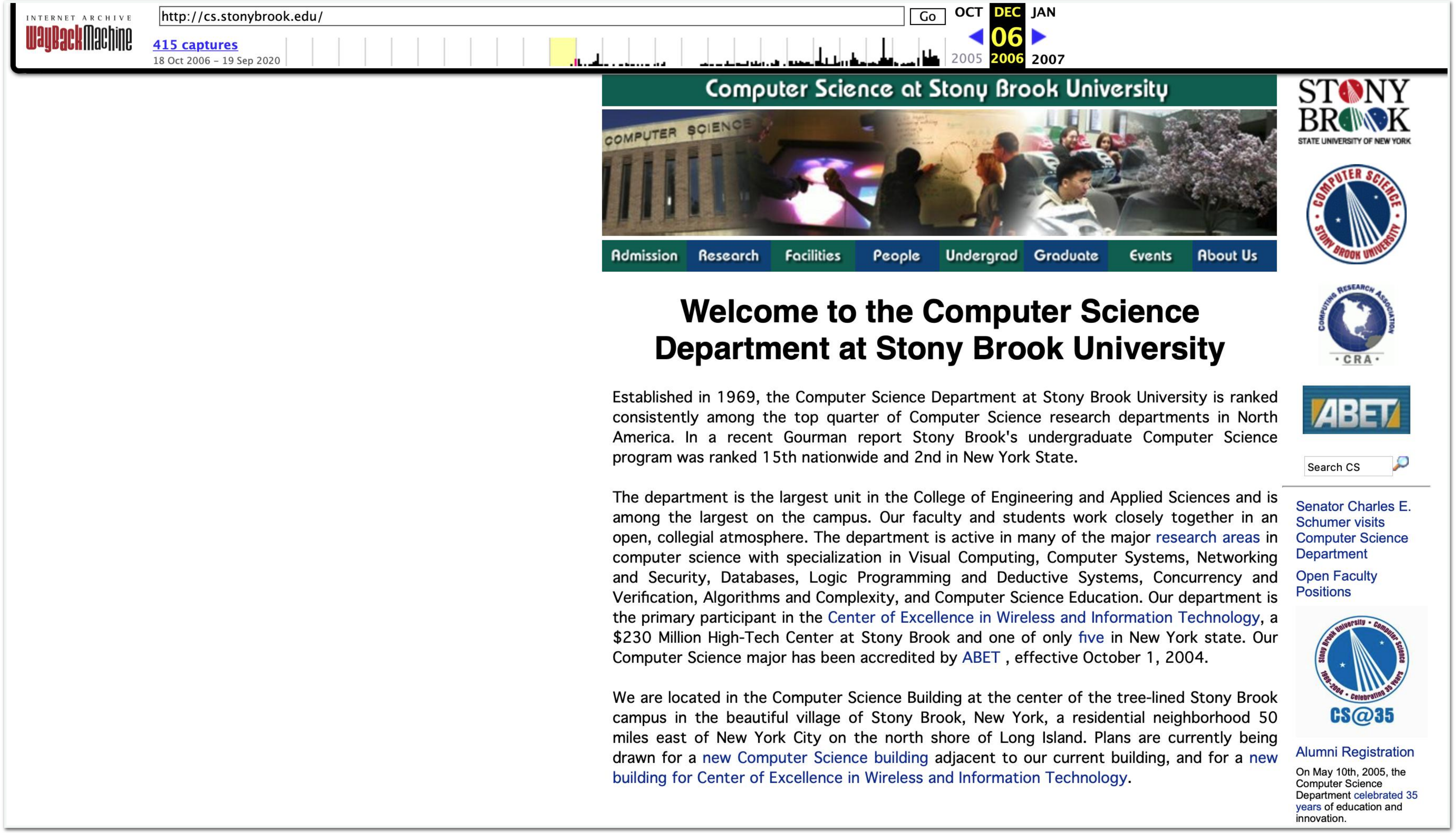
- Solution: time travel!



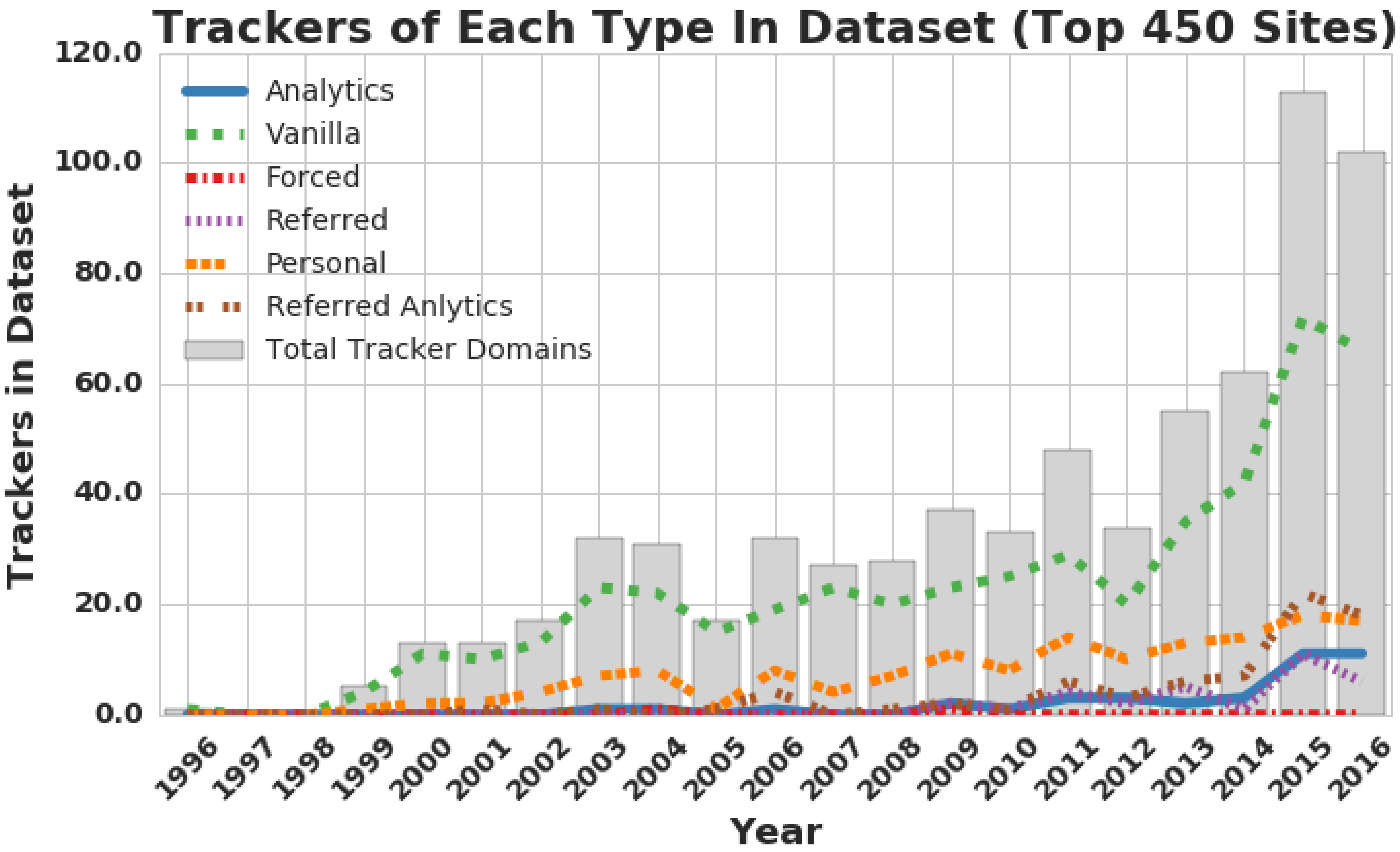
Internet Jones and the Raiders of the Lost Trackers:
An Archaeological Study of Web Tracking from 1996 to 2016

Adam Lerner*, Anna Kornfeld Simpson*, Tadayoshi Kohno, Franziska Roesner
University of Washington
{lerner,aksimpso,yoshi,franzi}@cs.washington.edu

The Wayback Machine to the Rescue

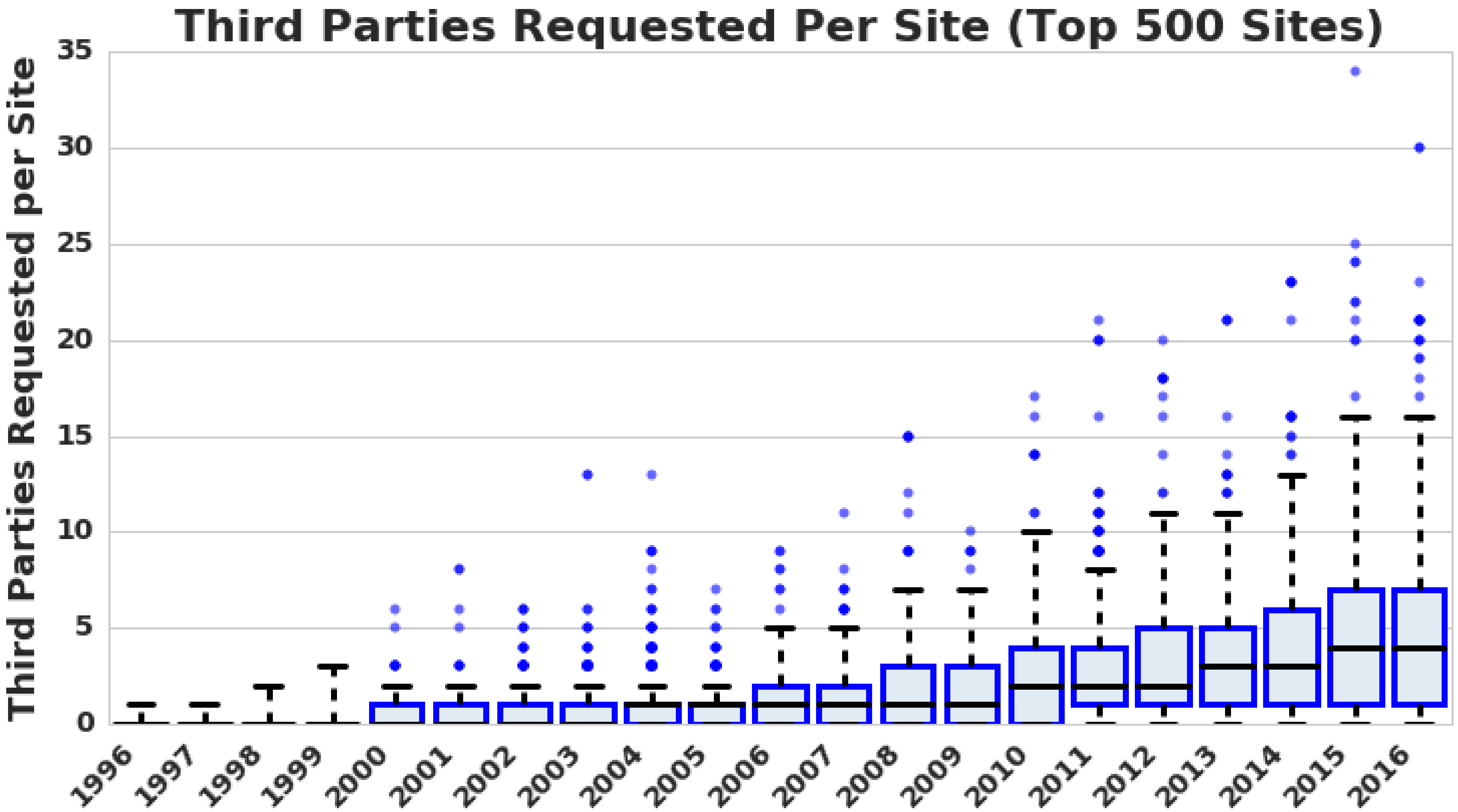


1996-2016: More & More Tracking



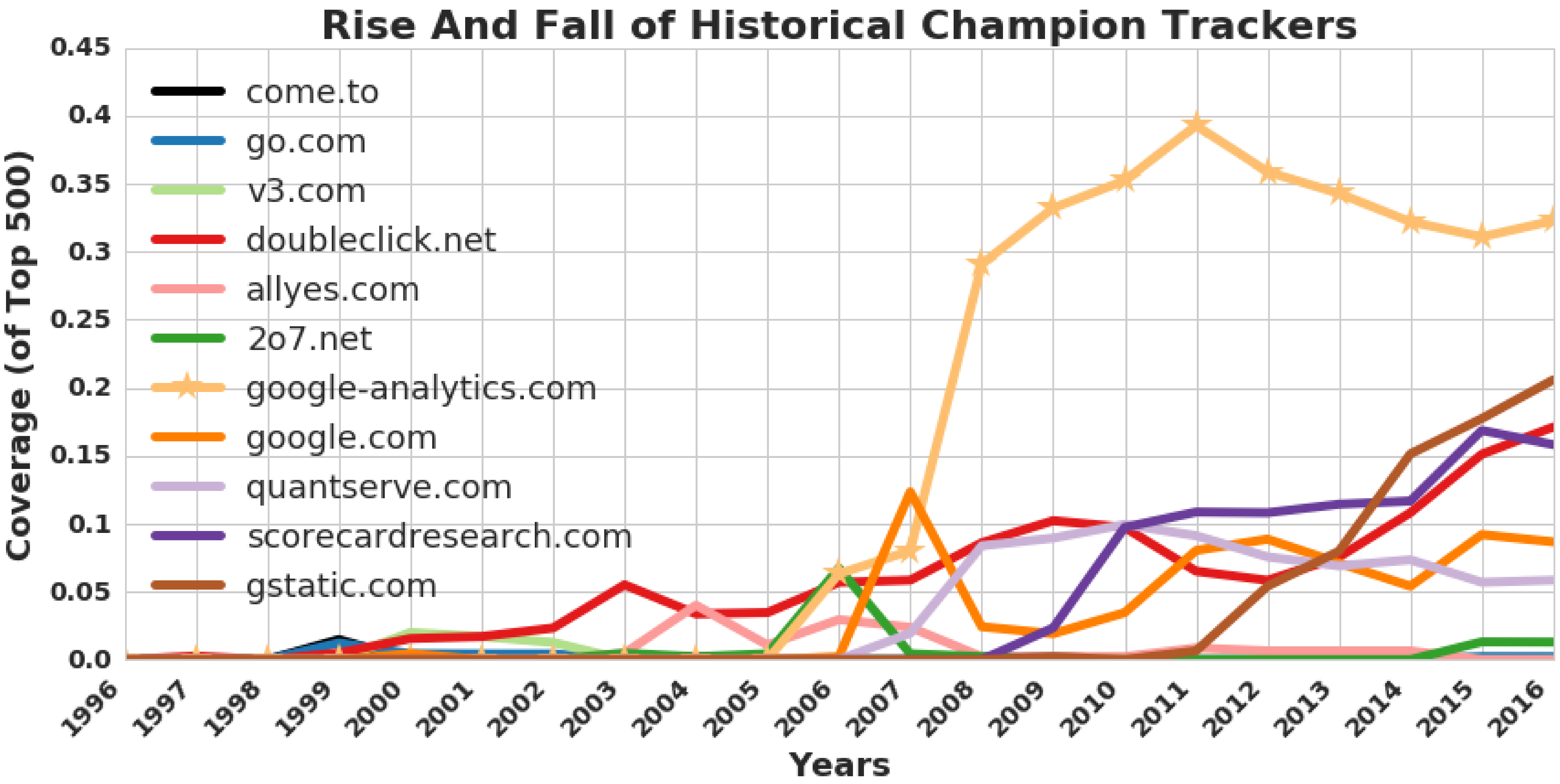
More trackers of more types

1996-2016: More & More Tracking



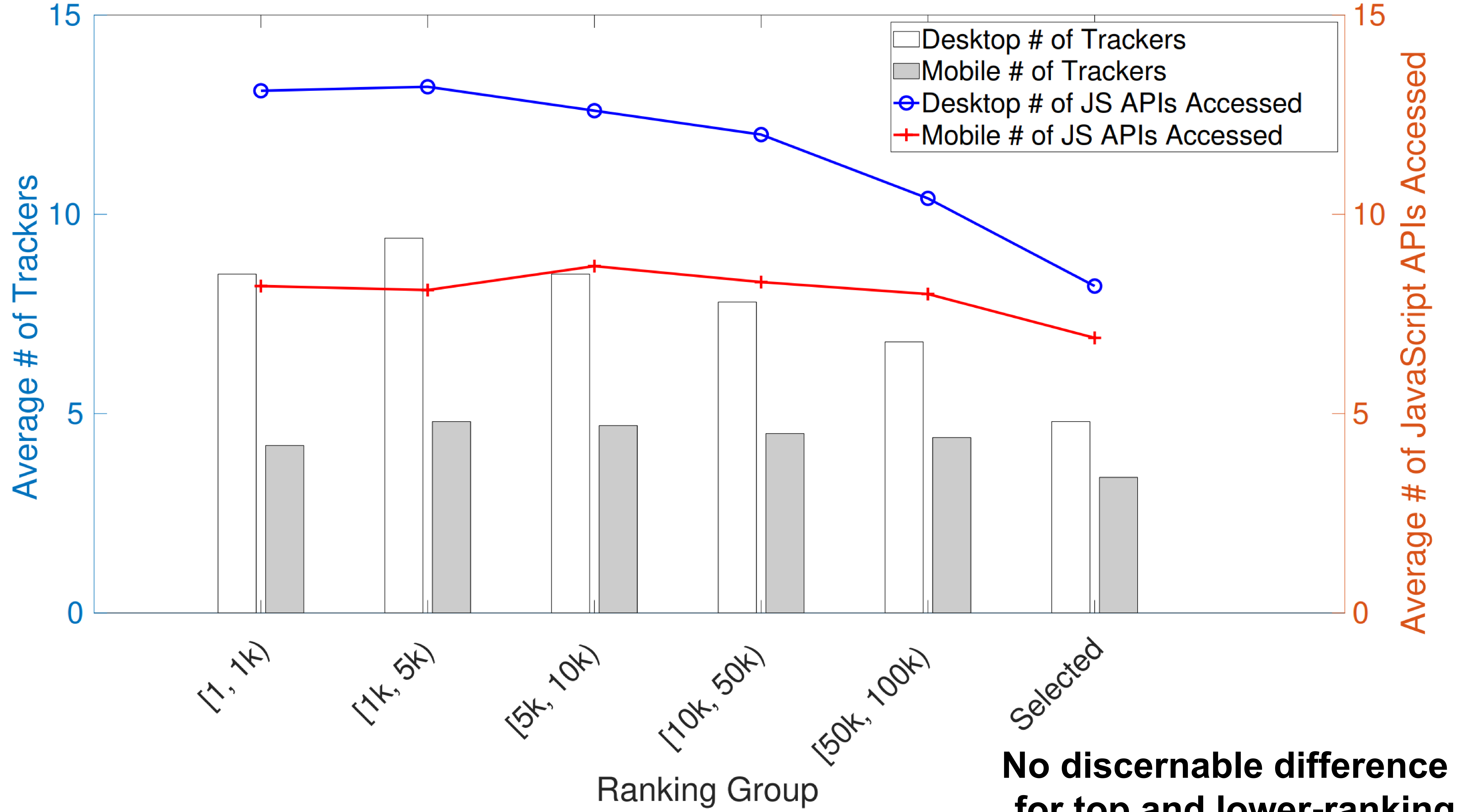
More trackers of more types, more per site

1996-2016: More & More Tracking



More trackers of more types, more per site, more coverage

Block Me If You Can (2022)



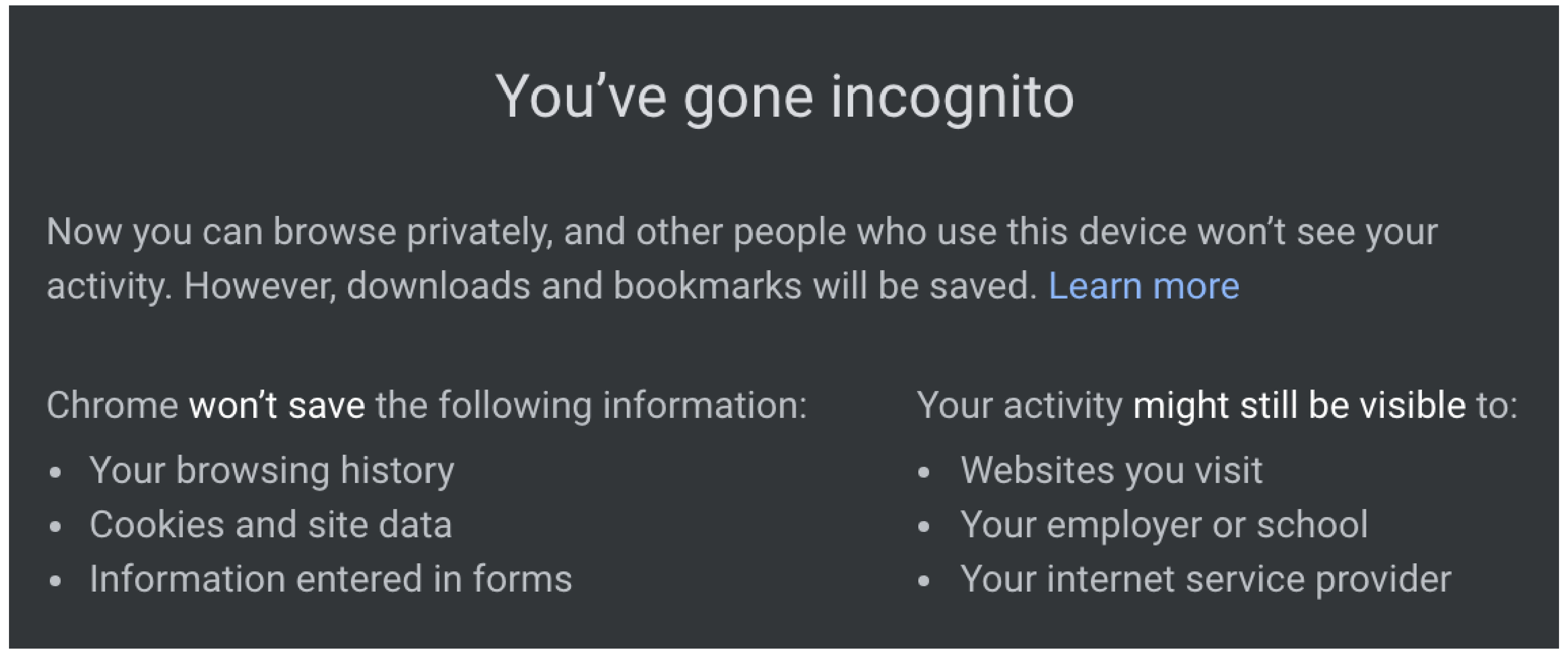
No discernable difference in tracking for top and lower-ranking websites.

Defenses to Reduce Tracking

Do Not Track (2010)

Do Not Track is not a technical defense: trackers must honor the request.

Private browsing mode



Private browsing mode does not save cookie. However, they are still active within a session

Defenses to Reduce Tracking

Browser add-ons

Often rely on blacklists, which may be incomplete.

Ghostery

Privacy Badger
A PROJECT OF THE ELECTRONIC FRONTIER FOUNDATION
BETA

"uses algorithmic methods to decide what is and isn't tracking"

Lightbeam
for Firefox

Tracking blockers may became trackers themselves!

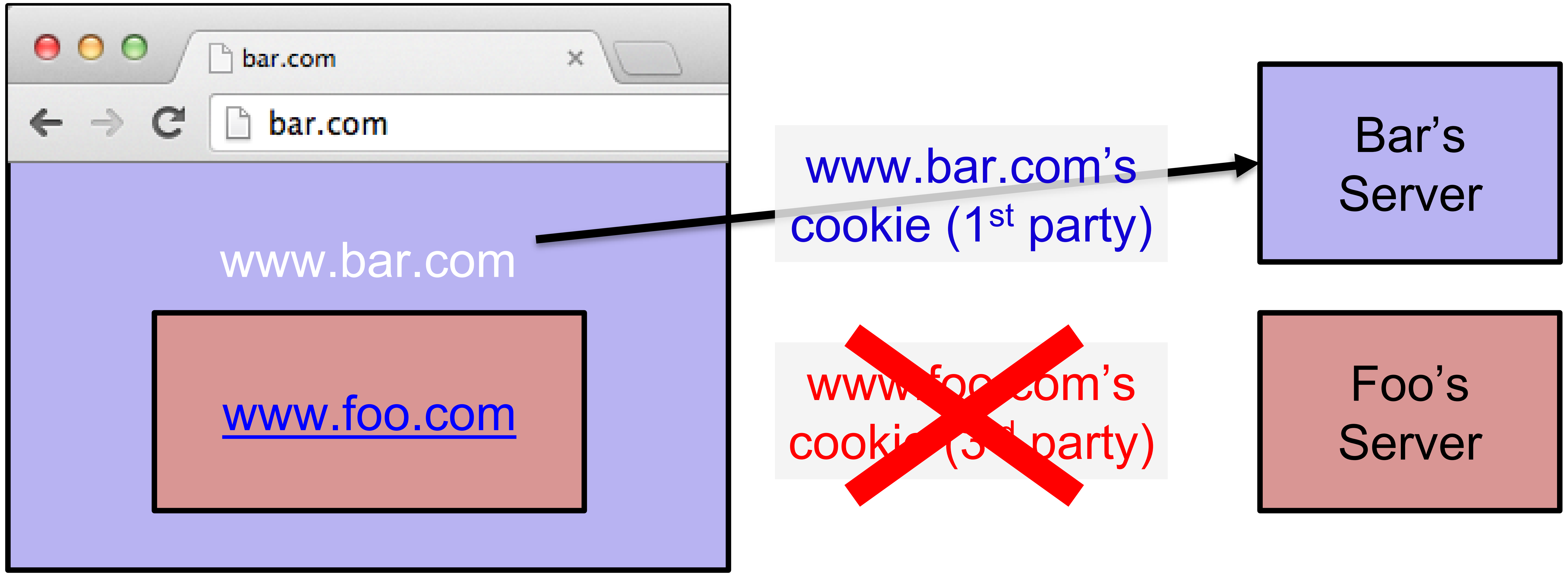
Previously, Ghostery sells its blocked list of trackers back to the advertising industry.

uBlock Origin

Look for open-source adblockers if you really need one.

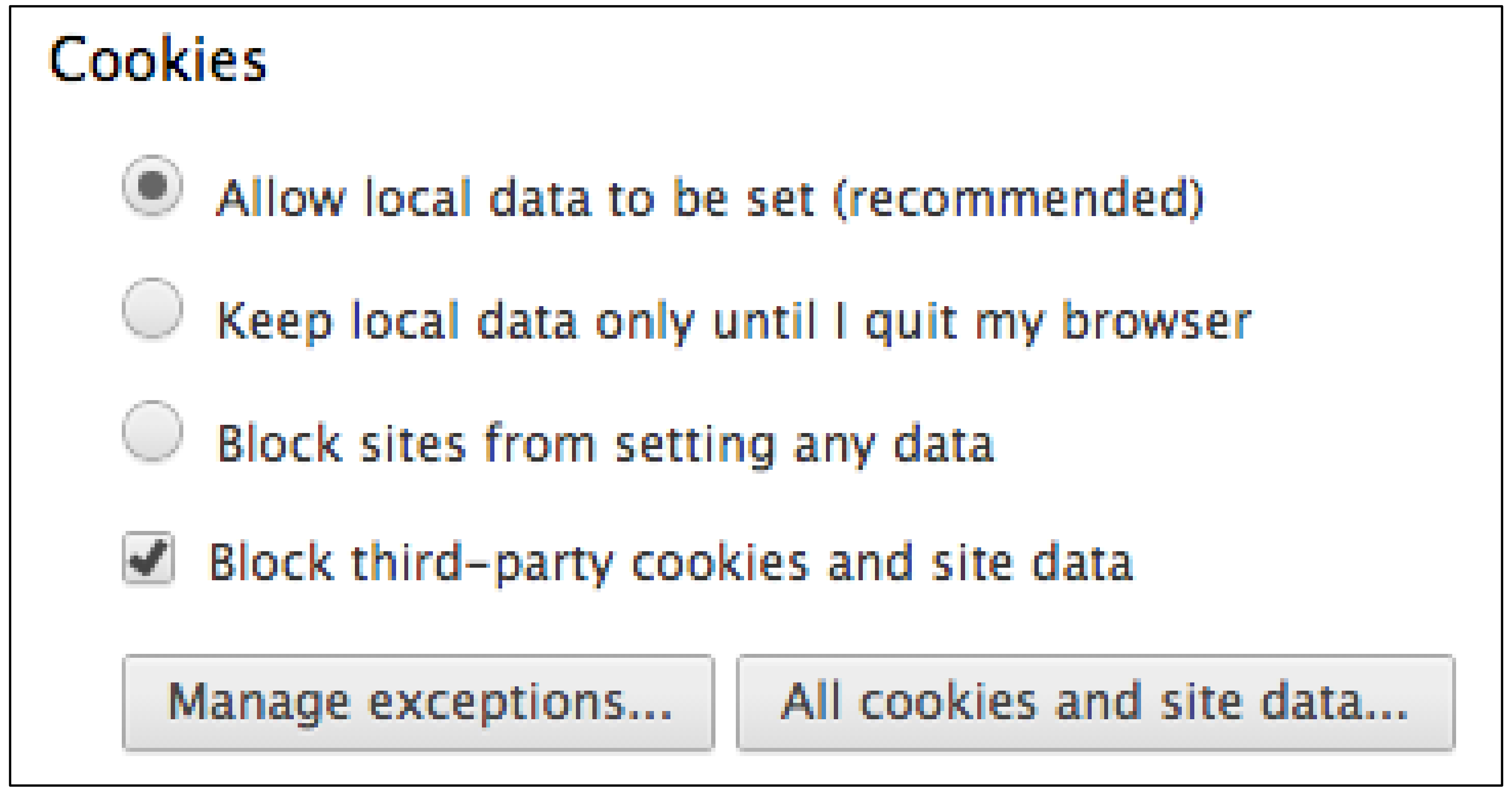
Defenses to Reduce Tracking

Third-party cookie blocking



Websites began prominently asking for cookie consent, largely due to the enforcement of the European Union's General Data Protection Regulation (GDPR) in May 2018, which requires explicit consent for processing personal data, including data collected through cookies.

Quirks of 3rd Party Cookie Blocking



In some browsers, this option means third-party cookies cannot be **set**, but they CAN be **sent**.

So if a third-party cookie is somehow set, it can be used.

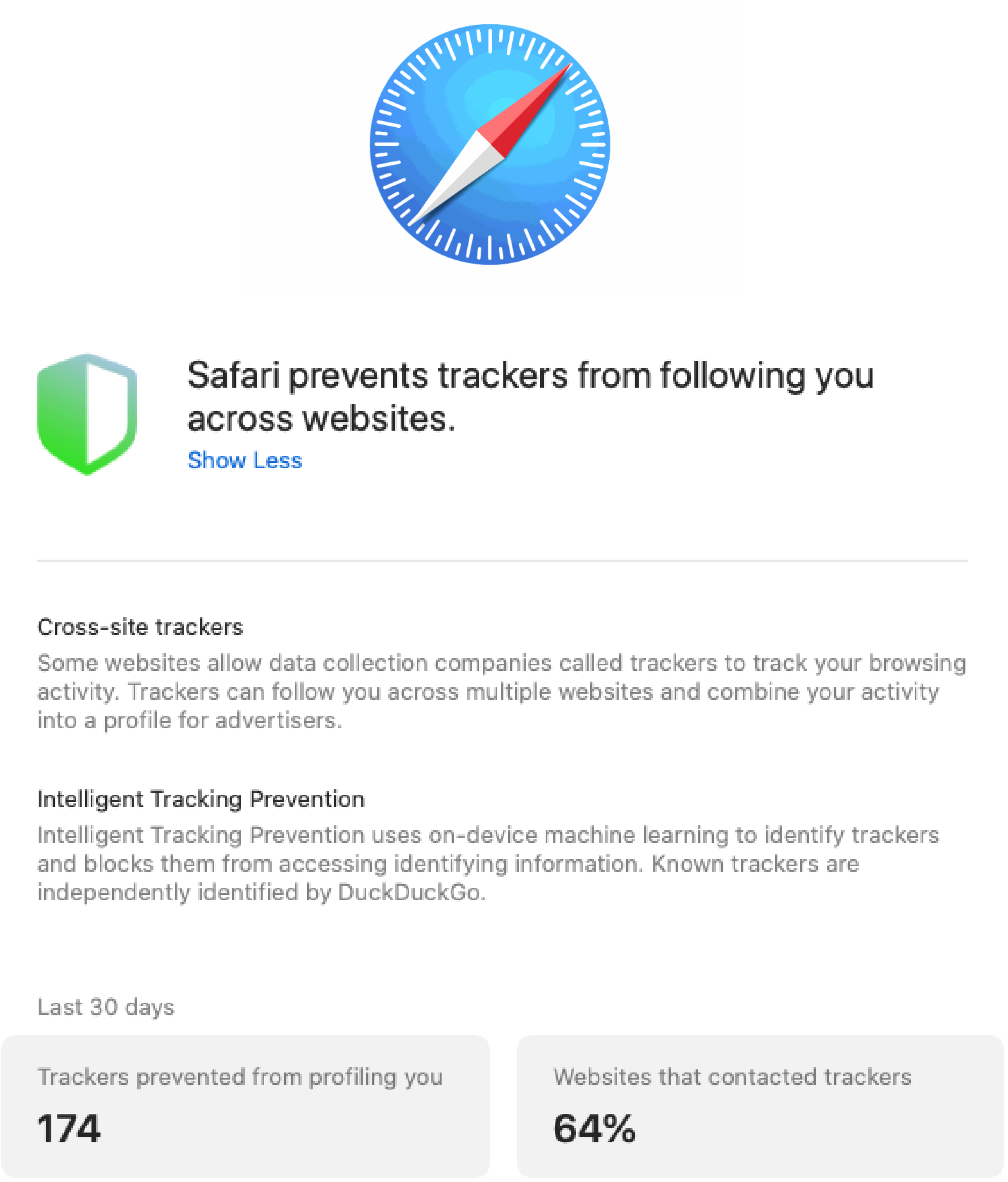
How to get a cookie set?

One way: be a first party.

etc.

Defenses to Reduce Tracking

Browsers getting involved

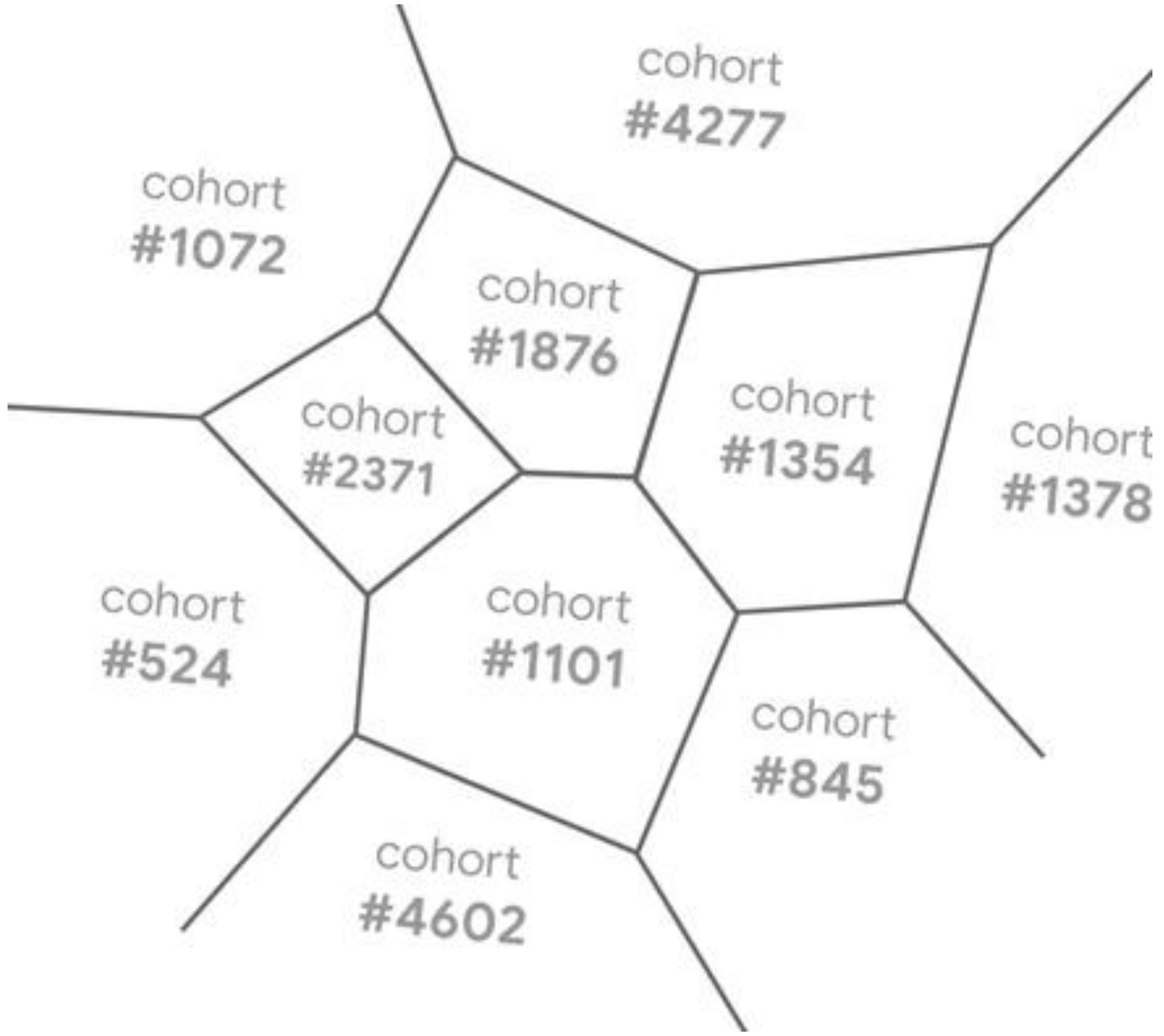


Safari and Firefox:

- These browsers already blocked third-party cookies years ago.
- You can still turn them on, but few bothers.
- If you use these browsers, the "death of 3rd party cookies" happened for you in 2017–2019.

Google’s Plan: Privacy Sandbox

- Block all third-party cookies
- Federated Learning of Cohorts (FLOC)



There was a time when third-party cookies seemed to be gone forever.

…Until the plan was cancelled in 2024, partly because it will give Google an unfair advantage.

Defenses to Reduce Tracking

Policy Solution:
General Data Protection Regulation (GDPR) 2018

- This regulation is the reason you see the “cookie consent” when you first visit a website.
- The European Union is behind the regulation.
- You may know that iPhone switched to USB-C also because of the EU regulations.